



Relatório de Auditoria de Segurança — JRC WhatsApp Broker

Fase 1

Incremento 2 — Console web operacional JRC

Referência da fonte

sha256:a3c00672ad28d95d3f8e4fe56521e48f0703b967996fea1747053ffc4078a826

Data de referência 2026-09-06

Resumo executivo

Foram consolidados 1 achado(s), 13 ponto(s) forte(s) e 176 rotas públicas. O gate bloqueia exclusivamente achados CRITICAL ou HIGH em estado OPEN.

1

Achados

0

Bloqueantes

13

Pontos fortes

Escopo e nota metodológica

Escopo: console web operacional, sessão de navegador, backend multicliente, PostgreSQL/RLS, autenticação, RBAC, API keys, instâncias, providers, OpenAPI, dependências, histórico Git JRC, bundles compilados e container. Permanecem fora: Meta real, mensageria, mídia, webhooks completos, billing, WhatsApp Calling, chatbot, filas e deploy.

Método: evidência em código e linhas, testes automatizados, inventário derivado do OpenAPI e scanners com saída sanitizada. O submódulo Evolution não é varrido historicamente; seu pin e sua fronteira são validados separadamente.

Eixos obrigatórios: isolamento multitenant; autorização não dependente somente do frontend; IDOR; exposição de segredos; inputs inseguros/XSS. Todos são aplicáveis neste incremento.

Categorias: CRITICAL — comprometimento imediato (P1); HIGH — impacto grave (P2); MEDIUM — impacto relevante condicionado (P3); LOW — hardening ou impacto limitado (P4); STRENGTH — controle positivo comprovado, sem efeito bloqueante.

CRITICAL

HIGH

MEDIUM

LOW

STRENGTH

Distribuição por severidade



Rosca por severidade

A rosca exclui INFO, reservado a contexto e não aplicabilidade. Ausência de segmentos indica zero achados CRITICAL, HIGH, MEDIUM ou LOW.

Evidências por categoria

AUTHENTICATION		1
AUTHORIZATION_RBAC		1
CONTAINER_RUNTIME		1
IDEMPOTENCY_DOS		1
IDOR		1
INPUTS_XSS		2
LOGGING_AUDIT		1
MULTITENANT_ISOLATION		1
OPENAPI_ROUTES		1
PROVIDER_BOUNDARY		1
RATE_LIMITING		1
SECRETS_CRYPTOGRAPHY		1
SUPPLY_CHAIN		1

Pontos fortes

JRC-STRENGTH-201

Troca de tenant invalida requests e estado local

O cliente incrementa a geração, aborta requests e executa os purges registrados antes de publicar a organização seguinte.

JRC-STRENGTH-202

Permissões do frontend são somente UX e o servidor permanece autoritativo

O navegador oculta ações incompatíveis com o papel, enquanto o guard Fastify revalida cada permissão no backend.

JRC-STRENGTH-203

Provider accounts e instâncias são resolvidos no tenant ativo

A organização vem da autenticação, a operação usa transação tenant e RLS, e identificadores de outro tenant não são revelados.

JRC-STRENGTH-204

Refresh HttpOnly e segredos voláteis no navegador

O refresh usa cookie host-only; access token fica em closure; QR, pairing e API key emitida são eliminados do estado volátil.

JRC-STRENGTH-205

Conteúdo não confiável não vira HTML ou navegação

React mantém escaping padrão e o QR é aceito somente como PNG base64 estrito, sem URL arbitrária nem dangerouslySetInnerHTML.

JRC-STRENGTH-206

Sessão de navegador valida Origin, CSRF e rotação

Rotas cookie-auth exigem origem exata e CSRF assinado; restore e switch rotacionam refresh com uso único.

JRC-STRENGTH-207

Rate limit distribuído persiste somente chaves HMAC

IP canônico e identidade normalizada são derivados com segredos distintos antes de entrar no Redis.

JRC-STRENGTH-208

Logger e E2E rejeitam canários sensíveis

A redaction estrutural cobre headers, cookies e desafios; o teardown falha se credenciais, QR, pairing ou identidade sintética chegarem aos logs.

JRC-STRENGTH-209

Evolution permanece atrás de contratos JRC

O registry separa provider comum e administrativo; a console usa apenas rotas JRC e o fake é admitido somente no runtime de teste.

JRC-STRENGTH-210

Intenções mutáveis são opacas, voláteis e reutilizadas com segurança

A UI preserva a mesma chave somente para retry incerto e cria outra após nova intenção; leases impedem duplicação concorrente no backend.

JRC-STRENGTH-211

Dependências e browser de teste são fixados no lockfile

CI usa npm ci, Node fixo, Playwright fixado, audit bloqueante para vulnerabilidades HIGH ou CRITICAL e um gate que confere os avisos das dependências distribuídas no browser.

JRC-STRENGTH-212

Contrato e inventário derivam da composição real

O OpenAPI é gerado deterministicamente pela aplicação e cada operação possui política explícita no inventário de segurança.

JRC-STRENGTH-213**Runtime imutável, mínimo e não-root**

A imagem fixa Node por tag e digest, separa build/runtime e executa o entrypoint compilado como usuário node.

Pontos fracos

JRC-SEC-201 · LOW/OPEN**Enforcement final de CSP e Permissions-Policy depende da camada de publicação**

O bundle e a API possuem controles próprios, mas o enforcement dos headers da página HTML depende da camada HTTPS que publicará a console, fora deste incremento sem deploy.

Tabela de achados

ID	Categoria	Severidade	Estado	Arquivo/linhas
JRC-SEC-201	INPUTS_XSS	LOW	OPEN	docs/operations/web-console.md:29-45

Prioridades

- P4 · JRC-SEC-201 — Enforcement final de CSP e Permissions-Policy depende da camada de publicação

Inventário de rotas

POST /hooks/{token}

Ownership: SECURITY_DEFINER_HASH_LOOKUP_THEN_RLS_ORGANIZATION
Handler: apps/api/src/http/routes/automation-webhooks.ts:17

OPAQUE_TOKEN_OPTIONAL_HMAC_TIMESTAMP ·
ACTIVE_BOUND_AUTOMATION · RLS SIM

GET /v1/api-keys

Ownership: RLS_ORGANIZATION_FILTER
Handler: apps/api/src/http/routes/api-keys.ts:136

JWT_OR_JRC_API_KEY · api_keys:manage · RLS SIM

POST /v1/api-keys

Ownership: ACTIVE_ORGANIZATION_CONTEXT
Handler: apps/api/src/http/routes/api-keys.ts:118

JWT_OR_JRC_API_KEY · api_keys:manage · RLS SIM

DELETE /v1/api-keys/{id}

Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID
Handler: apps/api/src/http/routes/api-keys.ts:153

JWT_OR_JRC_API_KEY · api_keys:manage · RLS SIM

POST /v1/auth/login

NONE · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: NOT_APPLICABLE_PRE_AUTH
Handler: apps/api/src/http/routes/auth.ts:148

POST /v1/auth/logout

REFRESH_TOKEN · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: REFRESH_TOKEN_FAMILY_BOUND
Handler: apps/api/src/http/routes/auth.ts:246

POST /v1/auth/refresh

REFRESH_TOKEN · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: REFRESH_TOKEN_TENANT_BOUND
Handler: apps/api/src/http/routes/auth.ts:223

POST /v1/auth/select-organization

SELECTION_TOKEN · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: SELECTION_TOKEN_MEMBERSHIP_REVALIDATED
Handler: apps/api/src/http/routes/auth.ts:192

POST /v1/automation-imports

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMPORT_ARTIFACT
Handler: apps/api/src/http/routes/automation-imports.ts:12

GET /v1/automation-nodes

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: STATIC_EXECUTABLE_NODE_CATALOG
Handler: apps/api/src/http/routes/automations.ts:27

GET /v1/automations

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_AUTOMATION_VERSION_BINDING_EXECUTION
Handler: apps/api/src/http/routes/automations.ts:28

POST /v1/automations

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX
Handler: apps/api/src/http/routes/automations.ts:35

GET /v1/automations/{id}

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_AUTOMATION_VERSION_BINDING_EXECUTION
Handler: apps/api/src/http/routes/automations.ts:36

PUT /v1/automations/{id}

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX
Handler: apps/api/src/http/routes/automations.ts:37

GET /v1/automations/{id}/bindings

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_AUTOMATION_VERSION_BINDING_EXECUTION
Handler: apps/api/src/http/routes/automations.ts:42

POST /v1/automations/{id}/bindings

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX
Handler: apps/api/src/http/routes/automations.ts:43

PATCH /v1/automations/{id}/bindings/{bindingId}

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX
Handler: apps/api/src/http/routes/automations.ts:44

POST /v1/automations/{id}/publish

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:40

POST /v1/automations/{id}/simulate

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:39

POST /v1/automations/{id}/validate

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:38

GET /v1/automations/{id}/versions

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_AUTOMATION_VERSION_BINDING_EXECUTION

Handler: apps/api/src/http/routes/automations.ts:41

GET /v1/automations/migrations/legacy

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_AUTOMATION_VERSION_BINDING_EXECUTION

Handler: apps/api/src/http/routes/automations.ts:30

POST /v1/automations/migrations/legacy

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:31

POST /v1/automations/migrations/legacy/{id}/cutover

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:32

POST /v1/automations/migrations/legacy/{id}/rollback

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:33

GET /v1/automations/status

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_AUTOMATION_VERSION_BINDING_EXECUTION

Handler: apps/api/src/http/routes/automations.ts:26

GET /v1/channels

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CANONICAL_CHANNEL_ID

Handler: apps/api/src/http/routes/channels.ts:53

POST /v1/channels

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_PROVIDER_ACCOUNT_AND_CHANNEL

Handler: apps/api/src/http/routes/channels.ts:66

GET /v1/channels/{id}

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CANONICAL_CHANNEL_ID

Handler: apps/api/src/http/routes/channels.ts:55

PATCH /v1/channels/{id}

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CANONICAL_CHANNEL_ID

Handler: apps/api/src/http/routes/channels.ts:58

GET /v1/channels/{id}/automation

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CANONICAL_CHANNEL_ID

Handler: apps/api/src/http/routes/channels.ts:96

PUT /v1/channels/{id}/automation

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_CHANNEL_AUTOMATION_AND_VERSION

Handler: apps/api/src/http/routes/channels.ts:100

PUT /v1/channels/{id}/destination

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_CHANNEL_ACCOUNT_AND_INBOX

Handler: apps/api/src/http/routes/channels.ts:104

POST /v1/channels/{id}/disconnect

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CANONICAL_CHANNEL_ID_BEFORE_PROVIDER

Handler: apps/api/src/http/routes/channels.ts:89

POST /v1/channels/{id}/pair

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CANONICAL_CHANNEL_ID_BEFORE_PROVIDER

Handler: apps/api/src/http/routes/channels.ts:73

POST /v1/channels/{id}/reconnect

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CANONICAL_CHANNEL_ID_BEFORE_PROVIDER

Handler: apps/api/src/http/routes/channels.ts:81

GET /v1/channels/{id}/status

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CANONICAL_CHANNEL_ID_BEFORE_PROVIDER

Handler: apps/api/src/http/routes/channels.ts:62

POST /v1/console/auth/logout

EXACT_ORIGIN_WITH_OPTIONAL_REFRESH_COOKIE_CSRF · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: REFRESH_TOKEN_FAMILY_WHEN_PRESENT

Handler: apps/api/src/http/routes/console-auth.ts:380

POST /v1/console/auth/restore

REFRESH_COOKIE_CSRF_AND_EXACT_ORIGIN · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: REFRESH_TOKEN_TENANT_BOUND

Handler: apps/api/src/http/routes/console-auth.ts:336

POST /v1/console/auth/select-organization

SELECTION_TOKEN_AND_EXACT_ORIGIN · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: SELECTION_TOKEN_MEMBERSHIP_REVALIDATED

Handler: apps/api/src/http/routes/console-auth.ts:313

POST /v1/console/auth/switch-organization

JWT_REFRESH_COOKIE_CSRF_AND_EXACT_ORIGIN · ACTIVE_MEMBERSHIP · RLS NÃO

Ownership: SOURCE_AND_TARGET_MEMBERSHIPS_REVALIDATED

Handler: apps/api/src/http/routes/console-auth.ts:353

GET /v1/credentials

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_CREDENTIAL

Handler: apps/api/src/http/routes/credentials.ts:17

POST /v1/credentials

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_CREDENTIAL

Handler: apps/api/src/http/routes/credentials.ts:18

DELETE /v1/credentials/{id}

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_CREDENTIAL

Handler: apps/api/src/http/routes/credentials.ts:21

GET /v1/credentials/{id}

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_CREDENTIAL

Handler: apps/api/src/http/routes/credentials.ts:19

PUT /v1/credentials/{id}

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_CREDENTIAL

Handler: apps/api/src/http/routes/credentials.ts:20

POST /v1/credentials/{id}/test

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_CREDENTIAL

Handler: apps/api/src/http/routes/credentials.ts:22

GET /v1/embed/apps/{id}/policy

PUBLIC_OPAQUE_APP_ID · APPROVED_ORIGIN_ONLY · RLS SIM

Ownership: SERVER_LOOKUP_RLS_ACTIVE_APP_ACCOUNT_DESTINATION

Handler: apps/api/src/http/routes/chatwoot-embed.ts:57

POST /v1/embed/authorizationsPUBLIC_CHALLENGE_RATE_LIMITED ·
START_WITHOUT_AUTHENTICATION_GRANT · RLS SIM

Ownership: SERVER_LOOKUP_RLS_ACTIVE_APP_ACCOUNT_DESTINATION

Handler: apps/api/src/http/routes/chatwoot-embed.ts:59

GET /v1/embed/authorizations/{id}JWT_CURRENT_MEMBERSHIP · CURRENT_CONNECTION_GRANTS · RLS
SIM

Ownership: RLS_PENDING_REQUEST_CURRENT_ACCOUNT_DESTINATION_GRANTS

Handler: apps/api/src/http/routes/chatwoot-embed.ts:66

POST /v1/embed/authorizations/{id}/approve

JWT_CSRF_EXACT_ORIGIN · CURRENT_CONNECTION_GRANTS · RLS SIM

Ownership: RLS_PENDING_REQUEST_CURRENT_ACCOUNT_DESTINATION_GRANTS

Handler: apps/api/src/http/routes/chatwoot-embed.ts:68

POST /v1/embed/authorizations/{id}/deny

JWT_CSRF_EXACT_ORIGIN · CURRENT_CONNECTION_GRANTS · RLS SIM

Ownership: RLS_PENDING_REQUEST_CURRENT_ACCOUNT_DESTINATION_GRANTS

Handler: apps/api/src/http/routes/chatwoot-embed.ts:71

POST /v1/embed/authorizations/{id}/exchangeSHA256_VERIFIER_TIMING_SAFE_RATE_LIMITED ·
EXPLICIT_APPROVAL_CURRENT_GRANTS · RLS SIM

Ownership: RLS_APPROVED_UNEXPIRED_REQUEST_USER_GRANTS_IDENTITY

Handler: apps/api/src/http/routes/chatwoot-embed.ts:74

POST /v1/embed/connections/{id}/pairOPAQUE_SHORT_SESSION_HASH_LOOKUP ·
SESSION_PAIR_GRANT_APPROVED_IDENTITY · RLS SIM

Ownership: RLS_CURRENT_SESSION_GRANT_BEFORE_DISPATCH_AFTER_RESPONSE

Handler: apps/api/src/http/routes/chatwoot-embed.ts:89

GET /v1/embed/connections/{id}/statusOPAQUE_SHORT_SESSION_HASH_LOOKUP ·
SESSION_READ_GRANT_CURRENT_MEMBERSHIP · RLS SIM

Ownership: RLS_SESSION_ACCOUNT_DESTINATION_CREDENTIAL_IDENTITY_REVISION

Handler: apps/api/src/http/routes/chatwoot-embed.ts:82

GET /v1/executions

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_AUTOMATION_VERSION_BINDING_EXECUTION

Handler: apps/api/src/http/routes/automations.ts:45

GET /v1/executions/{id}

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_AUTOMATION_VERSION_BINDING_EXECUTION

Handler: apps/api/src/http/routes/automations.ts:46

POST /v1/executions/{id}/cancel

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:47

POST /v1/executions/{id}/reconcile

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:49

POST /v1/executions/{id}/resume

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:50

POST /v1/executions/{id}/retry

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_IMMUTABLE_VERSION_DURABLE_EXECUTION_OUTBOX

Handler: apps/api/src/http/routes/automations.ts:48

GET /v1/flows

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:54

POST /v1/flows

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:62

GET /v1/flows/{id}

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:65

PUT /v1/flows/{id}

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:66

POST /v1/flows/{id}/bind

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:74

POST /v1/flows/{id}/chatwoot/bind

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:38

GET /v1/flows/{id}/chatwoot/runs

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:40

GET /v1/flows/{id}/export

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:67

POST /v1/flows/{id}/publish

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:73

GET /v1/flows/{id}/runs

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:76

POST /v1/flows/{id}/simulate

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:77

POST /v1/flows/{id}/unbind

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:75

POST /v1/flows/{id}/validate

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:70

GET /v1/flows/channels

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:55

POST /v1/flows/chatwoot/{id}/disable

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:39

POST /v1/flows/chatwoot/{id}/events

HMAC_TIMESTAMP_RAW_BODY · BOUND_AGENT_BOT · RLS SIM

Ownership: RLS_ACCOUNT_INBOX_DESTINATION_CREDENTIAL_FEATURE_REVISION

Handler: apps/api/src/http/routes/flows.ts:44

GET /v1/flows/chatwoot/inboxes

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:37

POST /v1/flows/import-preview

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_BINDING

Handler: apps/api/src/http/routes/flows.ts:59

GET /v1/flows/library

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:56

GET /v1/flows/status

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_FEATURE_AND_APPROVED_REMOTE_DESTINATION

Handler: apps/api/src/http/routes/flows.ts:53

GET /v1/instances

JWT_OR_JRC_API_KEY · instances:read · RLS SIM

Ownership: RLS_ORGANIZATION_FILTER_AND_TENANT_CURSOR

Handler: apps/api/src/http/routes/instances.ts:152

POST /v1/instances	JWT_OR_JRC_API_KEY · instances:connect · RLS SIM
Ownership: RLS_PROVIDER_ACCOUNT_AND_ORGANIZATION	
Handler: apps/api/src/http/routes/instances.ts:126	
GET /v1/instances/{id}	JWT_OR_JRC_API_KEY · instances:read · RLS SIM
Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID	
Handler: apps/api/src/http/routes/instances.ts:169	
POST /v1/instances/{id}/connect	JWT_OR_JRC_API_KEY · instances:connect · RLS SIM
Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID_BEFORE_PROVIDER	
Handler: apps/api/src/http/routes/instances.ts:183	
POST /v1/instances/{id}/disconnect	JWT_OR_JRC_API_KEY · instances:connect · RLS SIM
Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID_BEFORE_PROVIDER	
Handler: apps/api/src/http/routes/instances.ts:229	
PUT /v1/instances/{id}/settings	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_ACTIVE_ORGANIZATION_AUDITED · RLS SIM
Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID_BEFORE_PROVIDER	
Handler: apps/api/src/http/routes/instance-workspace.ts:27	
GET /v1/instances/{id}/status	JWT_OR_JRC_API_KEY · instances:read · RLS SIM
Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID_BEFORE_PROVIDER	
Handler: apps/api/src/http/routes/instances.ts:214	
GET /v1/instances/{id}/workspace	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM
Ownership: RLS_ORGANIZATION_AND_RESOURCE_ID_BEFORE_PROVIDER	
Handler: apps/api/src/http/routes/instance-workspace.ts:23	
GET /v1/integrations/chatwoot	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM
Ownership: RLS_ORGANIZATION_ONLY	
Handler: apps/api/src/http/routes/integrations.ts:166	
POST /v1/integrations/chatwoot/{id}/events	CHATWOOT_HMAC_TIMESTAMP_RAW_BODY · NOT_APPLICABLE_WEBHOOK · RLS SIM
Ownership: STORED_BINDING_SIGNATURE_ACCOUNT_INBOX_AND_RLS	
Handler: apps/api/src/http/routes/integrations.ts:352	
PUT /v1/integrations/chatwoot/account	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:184	
POST /v1/integrations/chatwoot/connections	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:218	
PATCH /v1/integrations/chatwoot/connections/{id}	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:268	
GET /v1/integrations/chatwoot/connections/{id}/agents	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:230	

POST /v1/integrations/chatwoot/connections/{id}/agents	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:235	
GET /v1/integrations/chatwoot/connections/{id}/operator-grants	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_CURRENT_ORGANIZATION_CONNECTION_MEMBERS_PROJECTION	
Handler: apps/api/src/http/routes/chatwoot-control.ts:91	
PUT /v1/integrations/chatwoot/connections/{id}/operator-grants	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ACTIVE_ORGANIZATION_CURRENT_MEMBERSHIP_AND_CONNECTION	
Handler: apps/api/src/http/routes/chatwoot-control.ts:94	
POST /v1/integrations/chatwoot/connections/{id}/reconcile	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:255	
POST /v1/integrations/chatwoot/connections/{id}/retry	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:120	
POST /v1/integrations/chatwoot/control-credentials	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ACTIVE_ORGANIZATION_APPROVED_ACCOUNT	
Handler: apps/api/src/http/routes/chatwoot-control.ts:88	
PUT /v1/integrations/chatwoot/control/connections/{integrationId}/agents	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_MANAGE · RLS SIM
Ownership: RLS_VALIDATED_ACCOUNT_AGENTS	
Handler: apps/api/src/http/routes/chatwoot-control.ts:70	
POST /v1/integrations/chatwoot/control/connections/{integrationId}/confirm-identity	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_MANAGE · RLS SIM
Ownership: RLS_ADMIN_PROVIDER_OBSERVED_IDENTITY	
Handler: apps/api/src/http/routes/chatwoot-control.ts:67	
POST /v1/integrations/chatwoot/control/connections/{integrationId}/disconnect	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_DISCONNECT · RLS SIM
Ownership: RLS_CURRENT_CONNECTION_ADMIN_OR_SERVICE	
Handler: apps/api/src/http/routes/chatwoot-control.ts:60	
POST /v1/integrations/chatwoot/control/connections/{integrationId}/pair	JWT_OR_BOUND_CONTROL_KEY · CHATWOOT_PAIR_AND_FIRST_BINDING_ADMIN · RLS SIM
Ownership: RLS_CURRENT_CONNECTION_GRANT_AND_PROVIDER_IDENTITY	
Handler: apps/api/src/http/routes/chatwoot-control.ts:53	
GET /v1/integrations/chatwoot/control/connections/{integrationId}/status	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_READ · RLS SIM
Ownership: RLS_ACCOUNT_REVISION_CONNECTION_GRANT	
Handler: apps/api/src/http/routes/chatwoot-control.ts:50	
GET /v1/integrations/chatwoot/control/context	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_READ · RLS SIM
Ownership: RLS_ACTIVE_ORGANIZATION_ACCOUNT_AND_DESTINATION_REVISION	
Handler: apps/api/src/http/routes/chatwoot-control.ts:36	
GET /v1/integrations/chatwoot/control/onboarding	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_MANAGE · RLS SIM
Ownership: RLS_CURRENT_ACCOUNT_REVISION_OPERATIONS	
Handler: apps/api/src/http/routes/chatwoot-control.ts:43	

POST /v1/integrations/chatwoot/control/onboarding	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_MANAGE · RLS SIM
Ownership: RLS_ACTIVE_ORGANIZATION_ACCOUNT_AND_DESTINATION_REVISION	
Handler: apps/api/src/http/routes/chatwoot-control.ts:73	
GET /v1/integrations/chatwoot/control/onboarding/{operationId}	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_READ · RLS SIM
Ownership: RLS_ACTIVE_ORGANIZATION_OPERATION_AND_INTEGRATION_GRANT	
Handler: apps/api/src/http/routes/chatwoot-control.ts:79	
POST /v1/integrations/chatwoot/control/onboarding/{operationId}/recover	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_MANAGE · RLS SIM
Ownership: RLS_ACTIVE_ORGANIZATION_ACCOUNT_AND_DESTINATION_REVISION	
Handler: apps/api/src/http/routes/chatwoot-control.ts:82	
GET /v1/integrations/chatwoot/control/resources	JWT_OR_BOUND_CONTROL_KEY · CURRENT_MEMBERSHIP_OR_CHATWOOT_MANAGE · RLS SIM
Ownership: RLS_SANITIZED_AVAILABLE_QR_RESOURCES	
Handler: apps/api/src/http/routes/chatwoot-control.ts:40	
GET /v1/integrations/chatwoot/destination	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM
Ownership: RLS_ORGANIZATION_ONLY	
Handler: apps/api/src/http/routes/integrations.ts:114	
PUT /v1/integrations/chatwoot/destination	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_AND_DESTINATION_NOT_IN_USE	
Handler: apps/api/src/http/routes/integrations.ts:117	
POST /v1/integrations/chatwoot/embed-apps	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_APPROVED_CURRENT_ACCOUNT_DESTINATION	
Handler: apps/api/src/http/routes/chatwoot-embed.ts:48	
GET /v1/integrations/chatwoot/embed-apps/{id}	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_APPROVED_CURRENT_ACCOUNT_DESTINATION	
Handler: apps/api/src/http/routes/chatwoot-embed.ts:51	
POST /v1/integrations/chatwoot/embed-apps/{id}/install	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ACCOUNT_DESTINATION_CREDENTIAL_REVISION_BEFORE_POST	
Handler: apps/api/src/http/routes/chatwoot-embed.ts:54	
GET /v1/integrations/chatwoot/inboxes	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:197	
GET /v1/integrations/chatwoot/jobs	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM
Ownership: RLS_ORGANIZATION_ONLY	
Handler: apps/api/src/http/routes/integrations.ts:287	
POST /v1/integrations/chatwoot/jobs/{id}/reconcile	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:141	
POST /v1/integrations/chatwoot/jobs/{id}/retry	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED	
Handler: apps/api/src/http/routes/integrations.ts:295	

GET /v1/integrations/chatwoot/sources

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED

Handler: apps/api/src/http/routes/integrations.ts:161

GET /v1/messaging/channels

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_FILTER

Handler: apps/api/src/http/routes/messaging.ts:312

PATCH /v1/messaging/channels/{id}/automation

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_CHANNEL_AND_SERVER_ORIGIN_ALLOWLIST

Handler: apps/api/src/http/routes/messaging.ts:392

GET /v1/messaging/channels/{id}/conversations

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CHANNEL_ID

Handler: apps/api/src/http/routes/messaging.ts:336

POST /v1/messaging/channels/{id}/messages

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_CHANNEL_CONVERSATION_AND_CONTACT_POLICY_BEFORE_OUTBOX

Handler: apps/api/src/http/routes/messaging.ts:362

GET /v1/messaging/channels/{id}/templates

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CHANNEL_ID_BEFORE_META

Handler: apps/api/src/http/routes/messaging.ts:323

POST /v1/messaging/channels/{id}/text

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_CHANNEL_CONVERSATION_AND_CONTACT_POLICY_BEFORE_OUTBOX

Handler: apps/api/src/http/routes/messaging.ts:277

GET /v1/messaging/conversations/{id}/messages

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CONVERSATION_ID

Handler: apps/api/src/http/routes/messaging.ts:349

PATCH /v1/messaging/conversations/{id}/mode

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN_OPERATOR · RLS SIM

Ownership: RLS_ORGANIZATION_AND_CONVERSATION_ID

Handler: apps/api/src/http/routes/messaging.ts:410

POST /v1/messaging/instances/{id}/activate

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_ACCOUNT_INBOX_AND_CHANNEL_VERIFIED

Handler: apps/api/src/http/routes/integrations.ts:314

GET /v1/messaging/media/{id}

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_ENCRYPTED_MEDIA_ATTACHMENT_ONLY

Handler: apps/api/src/http/routes/messaging.ts:256

POST /v1/messaging/messages/{id}/retry

JWT_WITH_ACTIVE_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_AND_SAFE_OUTBOX_STATE

Handler: apps/api/src/http/routes/messaging.ts:232

GET /v1/meta-onboarding

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_ASSETS_VERIFIED_BY_META

Handler: apps/api/src/http/routes/meta-onboarding.ts:28

POST /v1/meta-onboarding/{id}/refresh

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_ASSETS_VERIFIED_BY_META

Handler: apps/api/src/http/routes/meta-onboarding.ts:32

POST /v1/meta-onboarding/{id}/register

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_ASSETS_VERIFIED_BY_META

Handler: apps/api/src/http/routes/meta-onboarding.ts:33

POST /v1/meta-onboarding/{id}/revoke

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_ASSETS_VERIFIED_BY_META

Handler: apps/api/src/http/routes/meta-onboarding.ts:31

POST /v1/meta-onboarding/complete

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_ASSETS_VERIFIED_BY_META

Handler: apps/api/src/http/routes/meta-onboarding.ts:30

POST /v1/meta-onboarding/start

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_ORGANIZATION_ASSETS_VERIFIED_BY_META

Handler: apps/api/src/http/routes/meta-onboarding.ts:29

GET /v1/operations/health

JWT_CURRENT_MEMBERSHIP · CURRENT_MEMBER · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_HEALTH_AND_QUEUES

Handler: apps/api/src/http/routes/observability.ts:12

GET /v1/organization/operations

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_LIMITS

Handler: apps/api/src/http/routes/tenant-operations.ts:50

GET /v1/organization/overview

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN_OPERATOR_VIEWER · RLS SIM

Ownership: RLS_ORGANIZATION_AGGREGATES_NO_CONTENT

Handler: apps/api/src/http/routes/tenant-operations.ts:27

GET /v1/platform/auth/config

NONE · NOT_APPLICABLE_PRE_AUTH · RLS NÃO

Ownership: PUBLIC_MFA_POLICY_ONLY

Handler: apps/api/src/http/routes/platform.ts:176

POST /v1/platform/auth/login

CONFIGURED_PASSWORD_MODE_EXACT_ORIGIN · PLATFORM_IDENTITY · RLS SIM

Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT

Handler: apps/api/src/http/routes/platform.ts:183

POST /v1/platform/auth/logout

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · PLATFORM_IDENTITY · RLS SIM

Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT

Handler: apps/api/src/http/routes/platform.ts:210

GET /v1/platform/auth/session

PLATFORM_SESSION_COOKIE · PLATFORM_IDENTITY · RLS SIM

Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT

Handler: apps/api/src/http/routes/platform.ts:198

GET /v1/platform/organizations

PLATFORM_SESSION_COOKIE · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT

Handler: apps/api/src/http/routes/platform.ts:243

POST /v1/platform/organizations

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT

Handler: apps/api/src/http/routes/platform.ts:254

PATCH /v1/platform/organizations/{id}

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT

Handler: apps/api/src/http/routes/platform.ts:264

GET /v1/platform/organizations/{id}/chatwoot

PLATFORM_SESSION_COOKIE · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:363

PUT /v1/platform/organizations/{id}/chatwoot/account

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:392

POST /v1/platform/organizations/{id}/chatwoot/connections

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:426

PATCH /v1/platform/organizations/{id}/chatwoot/connections/{resourceId}

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:544

GET /v1/platform/organizations/{id}/chatwoot/connections/{resourceId}/agents

PLATFORM_SESSION_COOKIE · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:448

POST /v1/platform/organizations/{id}/chatwoot/connections/{resourceId}/agents

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:459

POST /v1/platform/organizations/{id}/chatwoot/connections/{resourceId}/reconcile

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:527

POST /v1/platform/organizations/{id}/chatwoot/connections/{resourceId}/retry

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:483

POST /v1/platform/organizations/{id}/chatwoot/destination/approve

PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_ROLE_AND_DESTINATION_REVISION

Handler: apps/api/src/http/routes/platform.ts:353

GET /v1/platform/organizations/{id}/chatwoot/inboxes

PLATFORM_SESSION_COOKIE · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:414

GET /v1/platform/organizations/{id}/chatwoot/jobs

PLATFORM_SESSION_COOKIE · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM

Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS

Handler: apps/api/src/http/routes/platform.ts:418

POST /v1/platform/organizations/{id}/chatwoot/jobs/{resourceId}/reconcile	PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS	
Handler: apps/api/src/http/routes/platform.ts:506	
POST /v1/platform/organizations/{id}/chatwoot/jobs/{resourceId}/retry	PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS	
Handler: apps/api/src/http/routes/platform.ts:563	
POST /v1/platform/organizations/{id}/chatwoot/provision	PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS	
Handler: apps/api/src/http/routes/platform.ts:582	
POST /v1/platform/organizations/{id}/chatwoot/provision/reconcile	PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS	
Handler: apps/api/src/http/routes/platform.ts:623	
POST /v1/platform/organizations/{id}/chatwoot/provision/resume	PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS	
Handler: apps/api/src/http/routes/platform.ts:603	
GET /v1/platform/organizations/{id}/chatwoot/sources	PLATFORM_SESSION_COOKIE · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_AUTHORIZATION_THEN_TENANT_RLS	
Handler: apps/api/src/http/routes/platform.ts:410	
GET /v1/platform/organizations/{id}/memberships	PLATFORM_SESSION_COOKIE · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT	
Handler: apps/api/src/http/routes/platform.ts:271	
PUT /v1/platform/organizations/{id}/memberships	PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT	
Handler: apps/api/src/http/routes/platform.ts:292	
GET /v1/platform/organizations/{id}/monitor	PLATFORM_SESSION_COOKIE · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT	
Handler: apps/api/src/http/routes/platform.ts:303	
POST /v1/platform/organizations/{id}/support-acknowledgment	PLATFORM_COOKIE_CSRF_EXACT_ORIGIN · SUPER_ADMIN_SUPPORT_AUDITED · RLS SIM
Ownership: DEDICATED_PLATFORM_ROLE_EXPLICIT_RLS_NO_CONTENT	
Handler: apps/api/src/http/routes/platform.ts:320	
GET /v1/provider-accounts	JWT_OR_JRC_API_KEY · instances:read · RLS SIM
Ownership: RLS_ORGANIZATION_FILTER_AND_TENANT_CURSOR	
Handler: apps/api/src/http/routes/provider-accounts.ts:74	
GET /v1/webhooks	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_CURRENT_ORGANIZATION_BINDING_CREDENTIAL	
Handler: apps/api/src/http/routes/automation-webhooks.ts:14	
POST /v1/webhooks	JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM
Ownership: RLS_CURRENT_ORGANIZATION_BINDING_CREDENTIAL	
Handler: apps/api/src/http/routes/automation-webhooks.ts:15	

DELETE /v1/webhooks/{id}

JWT_CURRENT_MEMBERSHIP · OWNER_ADMIN · RLS SIM

Ownership: RLS_CURRENT_ORGANIZATION_BINDING_CREDENTIAL

Handler: apps/api/src/http/routes/automation-webhooks.ts:16

GET /v1/webhooks/meta

META_VERIFY_TOKEN_QUERY · NOT_APPLICABLE_WEBHOOK · RLS NÃO

Ownership: SERVER_VERIFY_TOKEN_MATCH

Handler: apps/api/src/http/routes/meta-webhooks.ts:64

POST /v1/webhooks/metaMETA_HMAC_SHA256_RAW_BODY · NOT_APPLICABLE_WEBHOOK · RLS
SIM

Ownership: SERVER_ASSET_BINDING_AND_RLS_CHANNEL_MATCH

Handler: apps/api/src/http/routes/meta-webhooks.ts:78

Varredura sanitizada de segredos

- JRC_GIT_HISTORY: 0 ocorrência(s); escopo reachable root repository blobs; exclusões upstream/evolution-api/**, scripts/security/secret-canaries.mjs.
- COMPILED_BUNDLE: 0 ocorrência(s); escopo apps/api/dist/**, apps/web/dist/**, packages/contracts/dist/**, packages/providers/dist/**, packages/security/dist/**; exclusões **/*.map, node_modules/**, upstream/**.
- VITE_CONFIGURATION: 0 ocorrência(s); escopo process.env names, .env* variable names, apps/web/src production references; exclusões apps/web/src/**/*test.*, apps/web/src/**/*spec.*.

Issues completas

--- ISSUE 1 ---

JRC-SEC-201 — Enforcement final de CSP e Permissions-Policy depende da camada de publicação

Contexto

O Incremento 2 entrega o bundle e a integração local, mas não realiza deploy.

Evidência

`docs/operations/web-console.md:29-45`: política obrigatória da borda HTTPS.

Condições de exploração

Publicação futura sem os headers documentados ou fora da origem da API JRC.

Impacto

Redução da defesa em profundidade contra injeção de conteúdo e recursos desnecessários do navegador.

Correção

Aplicar CSP e Permissions-Policy na borda antes do go-live.

Critérios de aceite

- Console e `/v1` na mesma origem HTTPS.
- CSP sem `unsafe-eval`.
- Permissions-Policy restritiva.
- Teste dos headers no ambiente publicado.

Verificação

Inspeccionar os headers e executar o runbook de publicação.

Labels sugeridas

`security`, `frontend`, `deployment`, `hardening`

--- FIM ISSUE 1 ---